

ID	FECHA DE REGISTRO	RIESGO / EVENTO
ID-001	1/4/2025	Acceso no autorizado a sistemas bancarios móviles
ID-002	1/4/2025	Ataques de phishing dirigidos a usuarios bancarios
ID-003	1/4/2025	Vulnerabilidad en la app móvil
ID-004	1/4/2025	Pérdida de dispositivos móviles con información crítica
ID-005	1/4/2025	Inseguridad en la red de comunicación
ID-006	1/4/2025	Fugas de información por errores humanos
ID-007	1/4/2025	Caídas en el servicio de la app móvil
ID-008	1/4/2025	Errores en la autenticación multifactor
ID-009	1/4/2025	Problemas con la actualización de la aplicación
ID-010	1/4/2025	Sobrecarga de tráfico en la app móvil
ID-011	1/4/2025	Problemas con la conectividad de red
ID-012	1/4/2025	Incumplimiento de normativas legales

Potencial Consecuencia

Pérdida de fondos y datos confidenciales, sanciones legales y pérdida de confianza de los clientes.
Robo de datos sensibles de clientes, pérdidas financieras y daño a la reputación.
Exposición de datos sensibles de clientes, pérdida de integridad de las transacciones.
Acceso no autorizado a cuentas bancarias, robo de datos sensibles.
Exposición de datos bancarios y vulnerabilidad a ataques man-in-the-middle (MITM).
Exposición de información confidencial de clientes debido a errores operativos o negligencia.
Falta de disponibilidad, imposibilidad de realizar transacciones, pérdida de ingresos.
Acceso no autorizado a cuentas de usuarios legítimos, pérdida de fondos.
Pérdida de funcionalidad, errores operativos, inconvenientes para los usuarios.
Desempeño deficiente de la aplicación, interrumpiendo el acceso de los usuarios.
Interrupciones en el servicio, no se pueden realizar operaciones bancarias.
Multas y sanciones regulatorias, afectación a la reputación de la empresa.

Línea de Negocio	Macro Proceso	Proceso
BANCA ELECTRÓNICA	Gestión de Seguridad	Administración de Seguridad de la Información
BANCA ELECTRÓNICA	Gestión de Seguridad	Concientización y Educación al Cliente
BANCA ELECTRÓNICA	Gestión de Tecnología	Seguridad en la Aplicación
BANCA ELECTRÓNICA	Gestión de Seguridad	Protección de Datos
BANCA ELECTRÓNICA	Gestión de Tecnología	Seguridad en la Red
BANCA ELECTRÓNICA	Gestión Operativa	Gestión de Seguridad Interna
BANCA ELECTRÓNICA	Gestión Operativa	Mantenimiento de Infraestructura
BANCA ELECTRÓNICA	Gestión de Seguridad	Administración de Seguridad de la Información
BANCA ELECTRÓNICA	Gestión de Tecnología	Seguridad en la Aplicación
BANCA ELECTRÓNICA	Gestión Operativa	Gestión de Servicios de IT
BANCA ELECTRÓNICA	Gestión de Tecnología	Gestión de Infraestructura
BANCA ELECTRÓNICA	Gestión de Cumplimiento	Cumplimiento Normativo

Subproceso	Tipo de evento	Factor de riesgo
Gestión de Accesos	Tecnológico	Tecnologías de la Información
Capacitación continua	Tecnológico	Tecnologías de la Información
Evaluación de vulnerabilidades	Tecnológico	Tecnologías de la Información
Gestión de dispositivos móviles	Tecnológico	Tecnologías de la Información
Protección de redes de comunicación	Tecnológico	Tecnologías de la Información
Capacitación de Personal	Tecnológico	Tecnologías de la Información
Monitoreo de la Infraestructura	Tecnológico	Tecnologías de la Información
Gestión de Accesos	Tecnológico	Tecnologías de la Información
Implementación de Actualizaciones	Tecnológico	Tecnologías de la Información
Gestión de Tráfico en Línea	Tecnológico	Tecnologías de la Información
Redundancia de Red	Tecnológico	Tecnologías de la Información
Cumplimiento Legal	Tecnológico	Tecnologías de la Información

Fallas o insuficiencias	Subtipo de Riesgo	IMPACTO		
		C	I	D
Incumplimiento de normativa	Tecnológico	1	1	1
Falta de educación continua en seguridad	Tecnológico	2	2	1
No realización de pruebas de penetración regulares	Tecnológico	2	3	1
Falta de control de seguridad en dispositivos personales	Tecnológico	1	1	2
Uso de protocolos inseguros (HTTP en vez de HTTPS)	Tecnológico	2	2	3
Falta de un plan de capacitación continua	Tecnológico	2	1	1
Servidores no escalables o configurados adecuadamente	Tecnológico	2	1	2
Fallos en el proceso de verificación de MFA	Tecnológico	3	2	1
Parches de software no instalados a tiempo	Tecnológico	1	1	1
Capacidad insuficiente para manejar altos volúmenes de tráfico	Tecnológico	2	1	3
No existe redundancia en las conexiones de red	Tecnológico	2	1	2
Falta de auditorías regulares de cumplimiento	Tecnológico	1	3	1

CTO inicial IMP	PROBABILIDAD DE OCURRENCIA inicial	RIESGO INHERENTE inicial
B	M	2
M	M	3
M	M	3
B	M	2
M	M	3
B	M	2
M	M	3
M	M	3
B	M	2
M	M	3
M	M	3
B	M	2

CONTROLES existentes	EFFECTIVIDAD	PROMEDIO
Restricción de acceso a la plataforma móvil, solo para administradores.	1	1
Campañas periódicas de concientización sobre phishing.	2	2
Parches regulares en el código de la app.	2	2
Cifrado de dispositivos móviles.	1	1
Implementación de HTTPS y cifrado SSL.	2	2
Programas de formación y auditorías internas periódicas.	1	1
Servicios de cloud computing escalables.	2	2
Revisión de sistemas MFA.	1	1
Parches regulares y pruebas de compatibilidad en todas las versiones.	2	2
Optimización de los servidores y balanceo de carga.	2	2
Establecer redes redundantes y mejorar las conexiones.	3	3
Auditorías regulares y seguimiento a las normativas.	2	2

RIESGO NETO O RESIDUAL INICIAL	TRATAMIENTO / RESPUESTA
2	Mitigar
1.5	Tratar
1.5	Tratar
2	Mitigar
1.5	Tratar
2	Mitigar
1.5	Tratar
3	Mitigar
1	Tratar
1.5	Mitigar
1	Mitigar
1	Mitigar

Planes de mitigación	Fecha Final
Implementar MFA y monitoreo continuo de accesos y actividades sospechosas.	1/10/2025
Mejorar programas de capacitación y simulacros de phishing.	1/10/2025
Implementar pruebas de penetración continuas y auditorías.	1/10/2025
Implementar políticas de gestión de dispositivos móviles y bloqueo remoto.	1/10/2025
Reforzar la seguridad de la red e implementar protocolos seguros de comunicación.	1/10/2025
Implementar formación continua y auditorías internas.	1/10/2025
Implementar infraestructura en la nube y pruebas de resiliencia.	1/10/2025
Reforzar y revisar el proceso de autenticación multifactor.	1/10/2025
Implementar sistema de gestión de parches y versiones.	1/10/2025
Invertir en optimización de red y escalabilidad.	1/10/2025
Invertir en infraestructura de red de alta disponibilidad.	1/10/2025
Realizar auditorías legales internas y externas.	1/10/2025

PRESUPUESTO (cuando aplique)	LIMITACIONES / SUPUESTOS
\$50,000.00	Ninguna
\$5,000.00	Recursos limitados
\$20,000.00	Requiere tiempo de desarrollo
\$30,000.00	Costos adicionales por implementación
\$25,000.00	Capacitación continua
\$5,000.00	Disponibilidad del personal
\$40,000.00	Costo de infraestructura
\$15,000.00	Limitaciones tecnológicas
\$10,000.00	Requiere tiempo de desarrollo
\$50,000.00	Restricciones presupuestarias
\$60,000.00	Costos de infraestructura
\$20,000.00	Requiere aprobación legal

RESPONSABLE (¿Quién?)	Grado de Cumplimiento del plan	RIESGO NETO O RESIDUAL FINAL
Gerencia de TI	80% en los 6 primeros meses	2
Gerencia de Seguridad	75% en los 3 primeros meses	1.5
Gerencia de Tecnología	85% en los 6 primeros meses	1.5
Gerencia de Seguridad	90% en los 6 primeros meses	2
Gerencia de Tecnología	95% en los 6 primeros meses	1.5
Recursos Humanos	85% en los 3 primeros meses	2
Gerencia de Tecnología	90% en los 6 primeros meses	1.5
Gerencia de TI	90% en los 6 primeros meses	3
Gerencia de Tecnología	80% en los 6 primeros meses	1
Gerencia de Tecnología	85% en los 3 primeros meses	1.5
Gerencia de TI	90% en los 3 primeros meses	1
Gerencia de Cumplimiento	90% en los 6 primeros meses	1

COMENTARIOS / OBSERVACIONES

ISO 27001 A.9.1.2 / A.9.4.1

LOPDP Art. 39

ISO 27001 A.12.6.1

LOPDP Art. 7

ISO 27001 A.13.1

LOPDP Art. 7

ISO 27001 A.17.2.1

ISO 27001 A.9.4.2

ISO 27001 A.12.6.1

ISO 27001 A.17.1.3

ISO 27001 A.13.1

LOPDP, SB Res. 208-2018